

# Authentication

Authentication establishes the identity of a caller using credentials or an existing session. Authorization decides whether that identity may perform a specific action on a resource. In this course authentication is a prerequisite for authorization, and authorization is a prerequisite for document access control. A successful login alone does not grant permission to every PDF in an application.

# Authorization

Authorization evaluates whether a caller may perform an action on a resource. For a private PDF, compare the verified caller identity with the document owner or an explicit sharing rule. Authentication is a prerequisite for authorization. Authorization is a prerequisite for document access control. These checks belong on the server and must cover previews, retrieval, downloads, deletion, and graph queries, even if the interface hides buttons.

# Document Access Control

Document access control enforces ownership or sharing rules on every operation involving a document. Its direct prerequisite is authorization; authentication is the foundational prerequisite before authorization. Protect vector searches and graph traversals with the same document scope used for PDF previews. Guessing an upload identifier must never grant access. HTTPS protects transport, but it cannot replace these resource permission checks.

# Signed Sessions

A signed session cookie lets a server detect tampering and verify an expiry time. HttpOnly prevents page JavaScript from reading the cookie; Secure restricts transmission to HTTPS. A signature provides integrity, not secrecy, so session contents must not include secrets that require encryption. A stateless signed cookie does not by itself create per-user document ownership or provide instant revocation without additional state.

# Phishing

Phishing uses deceptive messages or websites to persuade a person to disclose credentials or perform an unsafe action. A message may manufacture urgency to discourage checking the sender. Verify unexpected requests through a separate trusted channel. HTTPS can encrypt a phishing website's traffic, so a secure connection is not proof that the operator is trustworthy. This lesson distinguishes transport protection from human deception.

# Rate Limits

Rate limits bound the number of requests a caller may make in a time window. Expensive AI operations can have a smaller budget than read-only metadata requests. HTTP 429 can tell a client to slow down. Rate limits control consumption but do not establish identity or document ownership. A shared reviewer code often maps all reviewers to one shared request budget and shared workspace.